

Network Fundamentals

Module 1- Networking Basics

What is a Network?

A network is a collection of **devices connected together so they can communicate and exchange data and resources**. Devices can include computers, servers, smartphones, printers, routers, switches, firewalls, and cloud systems. Communication happens through wired or wireless connections using agreed communication protocols.

In an organization, networking provides the infrastructure through which users access applications, databases, cloud services, websites, email, and other business resources. From a GRC perspective, a network is not just a technical infrastructure component—it is part of the organization's **technology and risk environment**. Network design directly affects confidentiality, integrity, availability, access control, monitoring, and business continuity.

A GRC professional needs enough networking knowledge to understand whether security controls are appropriately designed and whether risks such as unauthorized access, network intrusion, data interception, and lateral movement are being managed.

Networking knowledge becomes particularly important when reviewing:

- Firewall rules
- Network segmentation
- VPNs
- Access controls
- Cloud architecture
- Network monitoring
- Incident reports
- Security assessments
- Vendor environments

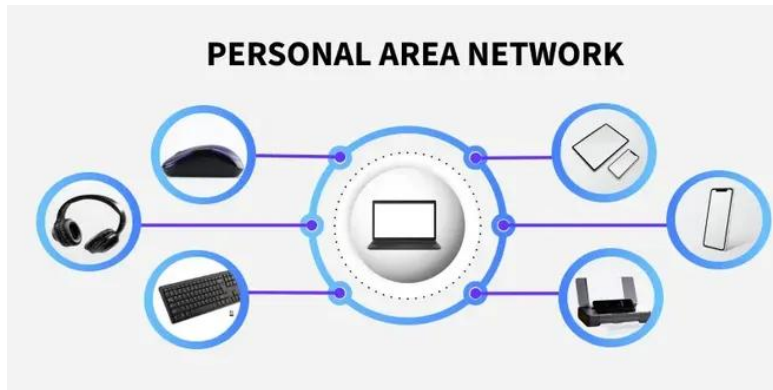
Personal Area Network (PAN)

A PAN is a short-range network that connects personal devices like smartphones, tablets, and computers. It typically covers less than 10 meters (about 33 feet) and usually uses wireless technologies such as Bluetooth. PAN is smaller than other networks like LAN or WAN and is mainly used for data sharing between a few devices.

- Allows for easy communication between personal devices in close proximity.
- Uses wireless technology, which eliminates the need for wires and cables.
- PANs are designed to be energy efficient, which means that devices can communicate with each other without draining their batteries quickly.

For GRC, this relates to:

- BYOD
- Mobile device security
- Wireless security
- Endpoint management
- Data leakage
- Acceptable-use policies



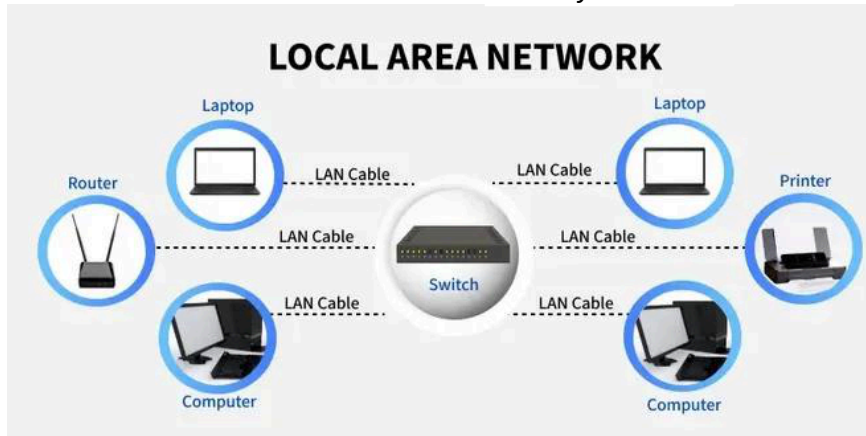
Local Area Network (LAN)

A LAN connects computers and devices within a small area like a home, office, school, or hospital. It usually uses switches, routers, and private IP addresses. LANs are high-speed, inexpensive to set up, and easy to maintain.

- **Coverage:** Up to 2 km (limited area).
- **Speed:** Earlier 4–16 Mbps; now 100–1000 Mbps.
- **Medium:** Mostly wired (Ethernet cables, twisted-pair, coaxial), though wireless can also be used.
- **Example:** Students playing a multiplayer game in the same room without internet.

For GRC, you'll encounter LAN concepts when assessing:

- Network segmentation
- Internal access controls
- Firewall architecture
- VLANs
- Wireless security
- Asset connectivity



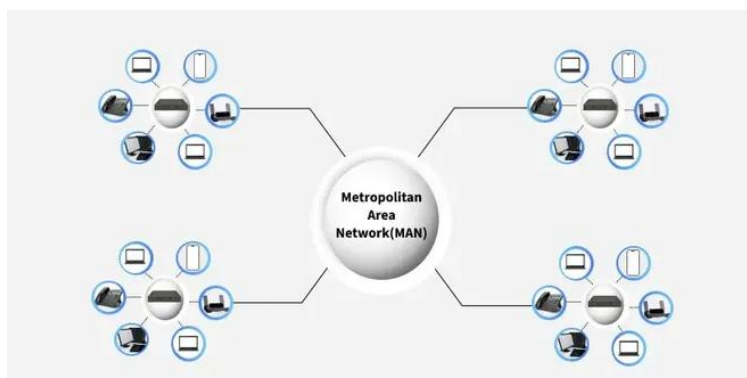
Metropolitan Area Network (MAN)

A MAN spans 5–50 km, covering more area than a LAN but less than a WAN. It connects computers across a city or between nearby cities. MANs provide high-speed connectivity (in Mbps), can act as ISPs, and are useful for organizations needing fast communication. However, they are costly, complex to design, and harder to maintain.

Understanding geographical network boundaries helps a GRC professional understand where organizational control begins and ends and which connectivity providers or third parties may be involved.

This can affect:

- Data transmission risks
- Physical security
- Availability
- Third-party dependencies
- Network monitoring

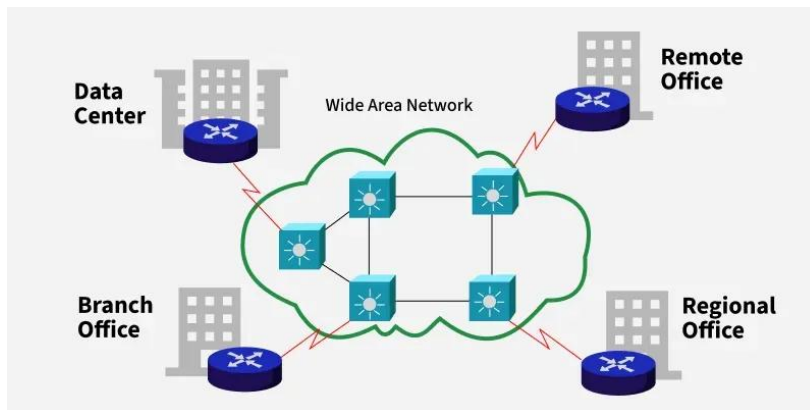


Wide Area Network (WAN)

A WAN covers large geographical areas (above 50 km), often connecting multiple LANs through telephone lines, radio waves, or satellites. It can be private (for organizations) or public (like the internet). WANs offer high-speed communication but are costly to set up and maintain.

For GRC, WAN security is relevant to:

- Remote connectivity
- Branch security
- VPN
- Network encryption
- Third-party connectivity
- Cloud connectivity
- Business continuity



Network Topologies

Network topology describes **how network devices and connections are physically or logically arranged**. Physical topology describes the actual physical connections, while logical topology describes how data flows through the network.

Common topologies include **star, bus, ring, mesh, and hybrid**. Modern enterprise Ethernet networks commonly use a hierarchical or star-like architecture where endpoints connect to switches, and switches connect to higher-level network infrastructure.

Topology affects network performance, scalability, fault tolerance, cost, and security.

Topology directly affects **availability and resilience**. Poor network design can create single points of failure or make network segmentation difficult.

GRC professionals need to understand topology when evaluating:

- Business continuity
- Disaster recovery
- Network resilience
- Single points of failure
- Segmentation
- Critical infrastructure

- **Star**
All devices connect to a central device such as a switch.
- **Bus**
Devices share a common communication backbone.
- **Ring**
Devices are connected in a circular arrangement.
- **Mesh**
Devices have multiple interconnections, providing redundancy.
- **Hybrid**
Combines multiple topology types.

Data Transmission

Data transmission is the process of **sending digital information from one device to another through a communication medium**. Data can travel through wired media such as Ethernet cables and fiber-optic cables or wireless media such as Wi-Fi and cellular networks.

Before transmission, data is divided and encapsulated according to networking protocols. The receiving system processes the transmitted information and reconstructs it into usable data.

Transmission involves concepts such as bandwidth, latency, transmission medium, packets, protocols, and error handling.

Data transmission is directly connected to **confidentiality, integrity, and availability**.

During transmission:

- Data may be intercepted.
- Data may be modified.
- Communication may be disrupted.
- Sensitive information may be exposed.

Therefore, secure protocols and encryption are important controls for protecting data in transit.

Bandwidth

Bandwidth represents the **maximum amount of data that can be transmitted over a network connection in a given period**, usually measured in bits per second.

Common measurements include:

- Mbps – Megabits per second
- Gbps – Gigabits per second

Bandwidth should not be confused with actual network speed or throughput. A connection may have high theoretical bandwidth but still experience poor performance because of congestion, latency, packet loss, or other limitations.

Bandwidth affects the capacity of business systems to handle users, applications, backups, cloud services, video conferencing, and other network traffic.

From a GRC perspective, insufficient bandwidth can become an **availability and business continuity risk**, particularly for critical business operations.

Module 2 – OSI Model

The OSI Model is a conceptual framework created by the International Organization for Standardization (ISO) to describe how data is transmitted across a network using a structured seven-layer architecture.

- Divides network communication into seven functional layers.
- Assigns specific responsibilities to each layer.
- Promotes compatibility between different networking systems.
- Simplifies network design, implementation, and troubleshooting.

Layer 1: The Physical Layer

The **Physical Layer** is the foundation of the OSI model, acting as the bridge for actual physical connections between devices. Its primary mission is the transmission of raw, unstructured bitstreams over a physical medium from one node to the next.

- **Core Responsibility:** It manages the hardware-level transmission of individual bits. When receiving data, it translates incoming physical signals back into digital 0s and 1s to be processed by the Data Link layer.
- **Essential Hardware:** Common devices operating at this level include [Hubs](#), [Repeaters](#), [Modems](#), and [Cables](#).
- **Bit Synchronization:** It ensures the sender and receiver are "in sync" by providing a clock signal that controls the timing of bit transmission.
- **Bit Rate Control:** It dictates the transmission speed, defined as the number of bits sent per second.
- **Physical Topologies:** It defines the structural layout of the network, such as Bus, Star, or Mesh configurations.
- **Transmission Mode:** It determines the direction of data flow, utilizing modes like Simplex (one-way), Half-Duplex (two-way, one at a time), or Full-Duplex (simultaneous two-way).



Layer 2: The Data Link Layer (DLL)

The Data Link Layer serves as the bridge between the physical hardware and the logical network, ensuring reliable node-to-node delivery of data. Its primary goal is to ensure that data transfer is error-free across the physical medium.

1. Data Packaging (Framing): At this layer, data packets received from the Network layer are divided into manageable units called Frames. This is done by adding specific "start" and "stop" bits so the receiver can recognize where one unit of data ends and the next begins.

2. Addressing and Hardware: The DLL uses MAC addresses (Physical Addressing) to identify hosts. It encapsulates the sender's and receiver's MAC addresses into the frame header. Common devices operating here are Switches and Bridges.

3. Sublayers:

- Logical Link Control (LLC): Manages flow and error control while acting as an interface for upper-layer protocols.
- Media Access Control (MAC): Determines how devices physically access the transmission medium and handles hardware addressing.

4. Error Control: It detects and retransmits damaged or lost frames to maintain data integrity.

5. Flow Control: It synchronizes the data rate between a fast sender and a slower receiver to prevent data "bottlenecks" or loss.

6. Access Control: When multiple devices share the same communication channel, the MAC sublayer dictates which device has the right to transmit at any given time to avoid collisions.

Layer 3: The Network Layer

The Network Layer manages data transmission between hosts across different networks by handling logical addressing and path finding.

- **Data Unit:** Data segments are encapsulated into Packets.
- **Logical Addressing:** Assigns unique IP addresses (sender and receiver) to the packet header to identify devices globally.
- **Routing:** Determines the most efficient physical path from the source to the destination across interconnected networks.
- **Hardware:** Primarily implemented via Routers and Switches.
- **Inter-networking:** Facilitates communication between disparate networks by directing traffic to the correct destination.

Layer 4: The Transport Layer

The Transport Layer ensures the end-to-end delivery of entire messages. It acts as a liaison, providing services to the Application layer while utilizing the infrastructure of the Network layer to ensure data reaches the correct application on the destination host.

- **Data Unit:** Data is broken down into Segments.
- **Service Point Addressing:** Uses Port Numbers (e.g., Port 80 for web traffic) to ensure data is delivered to the specific process or application intended, not just the device.
- **Segmentation & Reassembly:** Splits large messages into smaller segments for transmission and reassembles them in the correct order at the destination.
- **Protocols:** Common protocols include [TCP](#) (reliable), [UDP](#) (fast).
- **Connection-Oriented (TCP):** Requires a "handshake" to establish a connection; ensures reliability via error checking and acknowledgements.
- **Connectionless (UDP):** Sends data immediately without a formal connection; faster but offers no guarantee of delivery.

Layer 5: The Session Layer

The [Session Layer](#) acts as the "dialogue manager," governing the opening, closing, and security of communication channels between two devices.

- **Session Lifecycle:** Manages the establishment, maintenance, and termination of connections between applications.
- **Authentication & Security:** Ensures that the communicating parties are verified and the connection is secure.
- **Synchronization:** Inserts checkpoints into the data stream. This allows a transfer to resume from the last saved point if a failure occurs, rather than restarting from the beginning.
- **Dialog Control:** Directs whether communication is half-duplex (alternating) or full-duplex (simultaneous).
- **Practical Example:** In a web-based messenger, the Session Layer maintains the active link between your browser and the server, ensuring your specific chat remains open and synchronized while handling background encryption and data conveyance.

Layer 6: The Presentation Layer

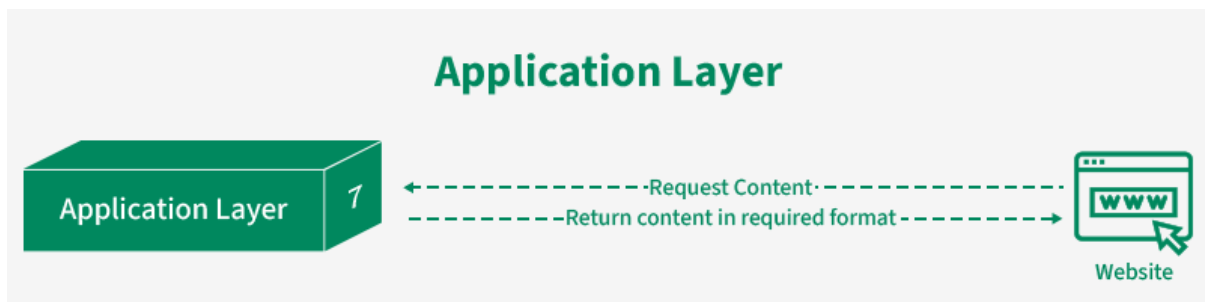
Often called the **Translation Layer**, the [Presentation Layer](#) ensures that data is formatted, secured, and compressed so that the receiving application can correctly interpret it.

- **Translation:** It extracts data from the Application Layer and converts it into a standardized format for network transmission, bridging differences in data representation between different systems.
- **Standards & Formats:** Handles the encoding of media using standards such as [JPEG](#), [MPEG](#), and [GIF](#).
- **Encryption/Decryption:** Provides security by converting "plain text" into "ciphertext" (encryption) and back again (decryption) using key values. This process is typically handled by protocols like [TLS/SSL](#).
- **Compression:** Reduces the total number of bits required for transmission, which increases network efficiency and speed.

Layer 7: The Application Layer

The **Application Layer** sits at the top of the OSI stack and serves as the direct interface between the software user and the network. It produces the data that will be sent and displays the information received from other layers.

- **User Interface:** Acts as a "window" for network-based applications (like web browsers or email clients) to access network services.
- **Core Protocols:** Utilizes high-level protocols such as **HTTP/S** (Web), **SMTP** (Email), **FTP** (File Transfer), and **DNS** (Domain Name Resolution).
- **Network Virtual Terminal (NVT):** Enables users to log into and interact with remote hosts as if they were physically present at the terminal.
- **File Transfer, Access, and Management (FTAM):** Provides the framework for users to retrieve, manage, and manipulate files stored on remote computers.
- **Directory Services:** Offers distributed database access to manage global information regarding various network objects and services.



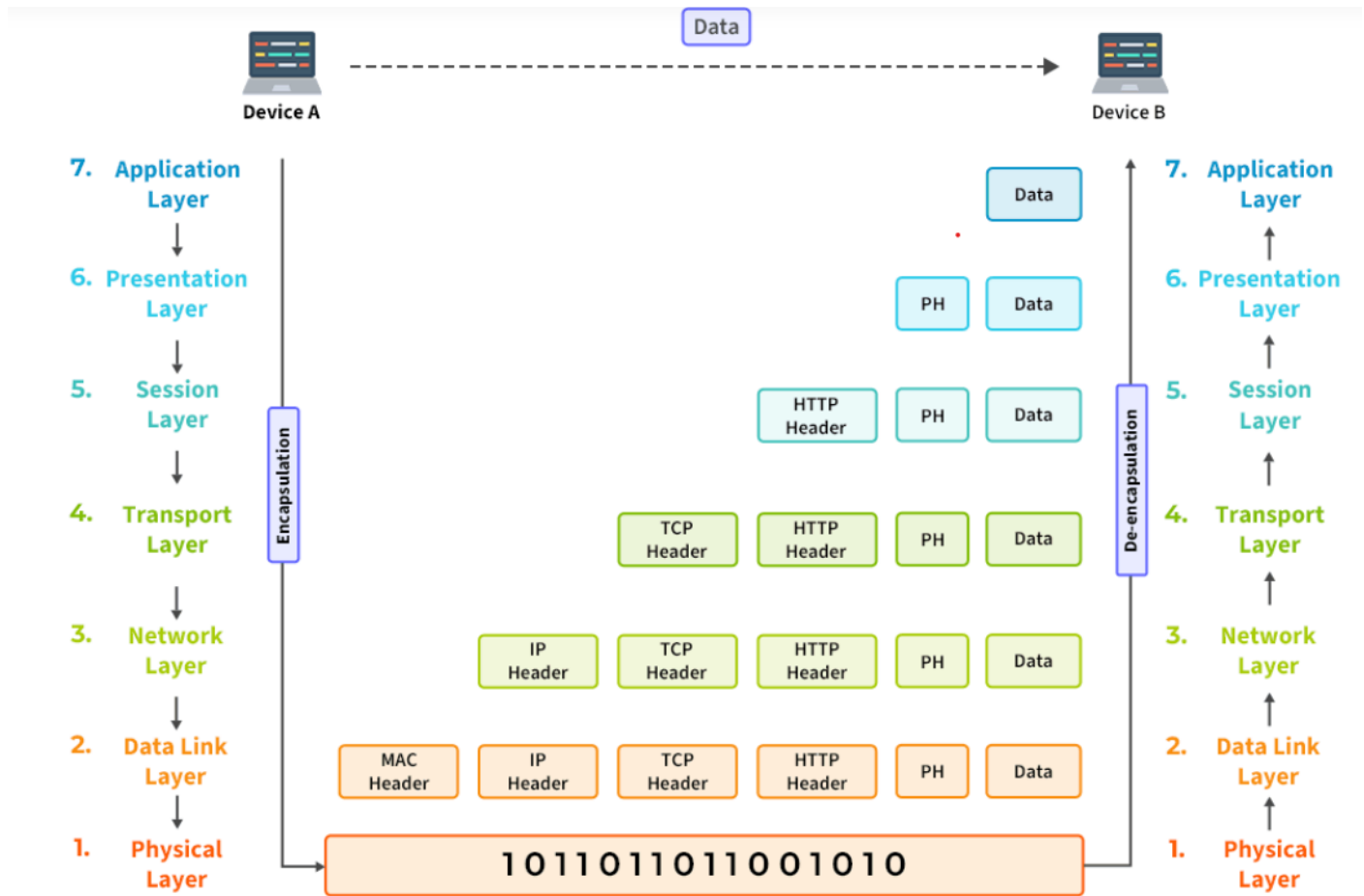
Application Layer

Data Flows in the OSI Model

When we transfer information from one device to another, it travels through 7 layers of OSI model. First data travels down through 7 layers from the sender's end and then climbs back 7 layers on the receiver's end. Data flows through the OSI model in a step-by-step process:

- **Application Layer:** Applications create the data.
- **Presentation Layer:** Data is formatted and encrypted.
- **Session Layer:** Connections are established and managed.
- **Transport Layer:** Data is broken into segments for reliable delivery.
- **Network Layer:** Segments are packaged into packets and routed.
- **Data Link Layer:** Packets are framed and sent to the next device.
- **Physical Layer:** Frames are converted into bits and transmitted physically.

Each layer adds specific information to ensure the data reaches its destination correctly, and these steps are reversed upon arrival.



OSI-Based Troubleshooting

OSI-based troubleshooting is a structured method of identifying network problems by examining communication layer by layer. Instead of randomly changing configurations, the problem is investigated systematically to identify where communication is failing.

Troubleshooting can begin from the lowest layer and move upward or start from the application and move downward, depending on the situation.

The main principle is simple: **identify which layer is failing before deciding how to fix the problem.**

For a GRC professional, you are unlikely to perform deep technical troubleshooting every day, but understanding this approach is useful when reviewing incidents, outages, root-cause analyses, and corrective actions.

It helps you ask better questions such as:

- Was this a physical infrastructure failure?
- Was there a routing problem?
- Did a firewall rule block traffic?

- Did DNS fail?
- Did the application itself fail?

This is especially useful when assessing whether the root cause and corrective action in an incident report are actually appropriate.

Bottom-Up Approach

Start from Layer 1 and move upward:

- Are cables or wireless connections working?
- Is the local network connection available?
- Is routing working?
- Is transport communication available?
- Is the application functioning?

Top-Down Approach

Start from the application:

- Is the application available?
- Is the correct protocol functioning?
- Is network communication available?
- Is physical connectivity working?

Security-Relevant Failures

- Firewall misconfiguration
- DNS failure
- Routing error
- Certificate issue
- Blocked port
- Network outage
- Unauthorized configuration change

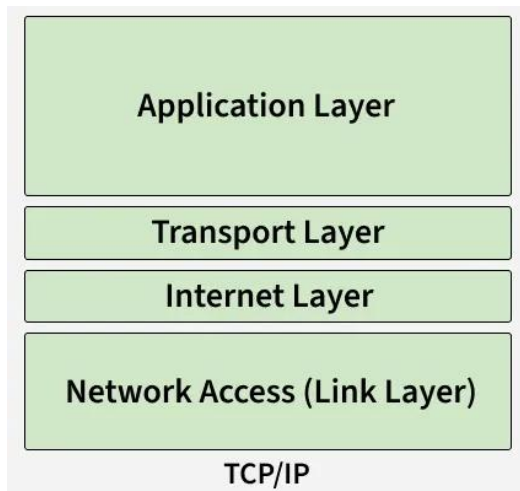
Module 3 – TCP/IP

The TCP/IP model is the practical networking model used by the Internet and most modern enterprise networks. Unlike the OSI model, which has seven layers, TCP/IP groups networking functions into broader layers. The roadmap topics here focus on the **Internet Layer, Transport Layer, Application Layer, Encapsulation, and Packet Flow**.

The TCP/IP model is a layered networking framework that explains how data is communicated between devices over a network using standardized protocols to ensure reliable and efficient transmission.

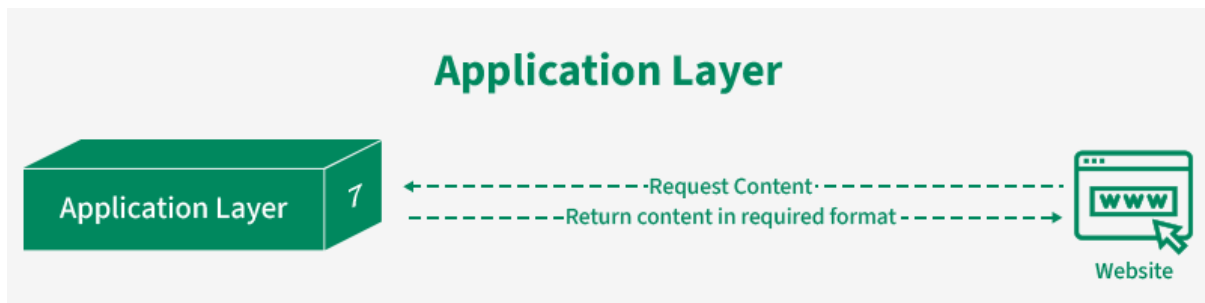
- Defined as a four-layer architecture consisting of Application, Transport, Internet, and Network Access layers.

- Standardized by RFC 1122, which specifies its structure and behavior.
- Simpler and more practical than the seven-layer OSI model.
- Serves as the core framework of the modern Internet and networking systems.



1. Application Layer

This is the top layer of the TCP/IP model, where applications like web browsers, email clients, and file-sharing tools interact with the network.



Application Layer

- Acts as a bridge between user applications and lower network layers.
- Supports protocols such as HTTP, FTP, SMTP, and DNS.
- Handles data formatting so information is correctly understood by both sender and receiver.
- Provides encryption for secure communication.
- Manages sessions to track ongoing connections.

For GRC, Application Layer security is highly relevant because organizations depend on business applications to process sensitive information.

You need to understand:

- Which services are exposed
- Which protocols are approved
- Whether encryption is used
- Whether legacy protocols are prohibited

- How access is controlled
- Whether applications are monitored

2. Transport Layer

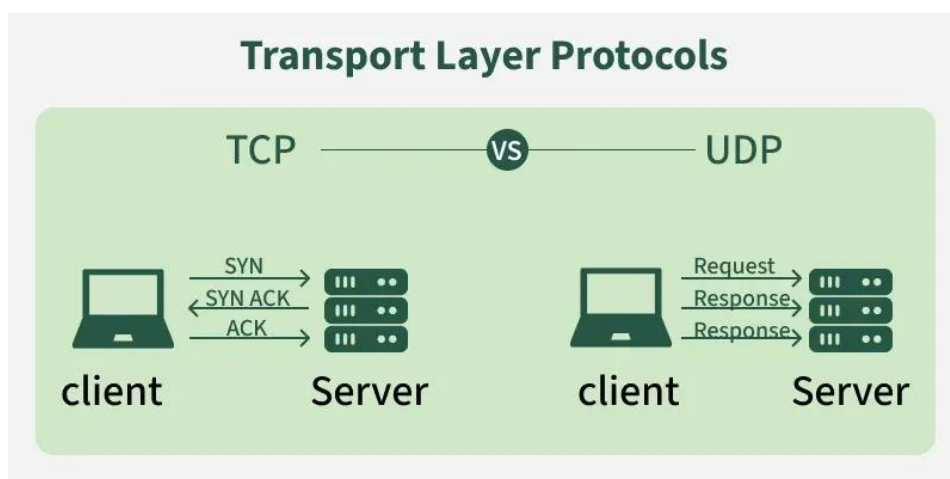
Ensures reliable and efficient delivery of data between devices, managing segmentation, ordering, and retransmission as needed.

- Breaks large messages into packets and reassembles them at the destination.
- TCP checks for errors, resends lost data, and ensures correct order.
- UDP provides low-latency, connectionless delivery without error checking.
- Prevents the receiver from being overwhelmed by regulating data flow.
- Uses port numbers to allow multiple applications to share the network simultaneously.

Transport Layer security is relevant to:

- Open ports
- Network services
- Firewall rules
- Secure application communication
- Network exposure
- Vulnerability assessments

GRC professionals frequently encounter reports showing open ports and exposed services. Understanding that a port represents an application communication endpoint is essential when assessing whether exposure is justified.



Transport Layers

TCP (Transmission Control Protocol): TCP is used when reliability and accuracy are important. It ensures that data is delivered exactly as sent.

- TCP detects errors in the data using checksums to ensure integrity.

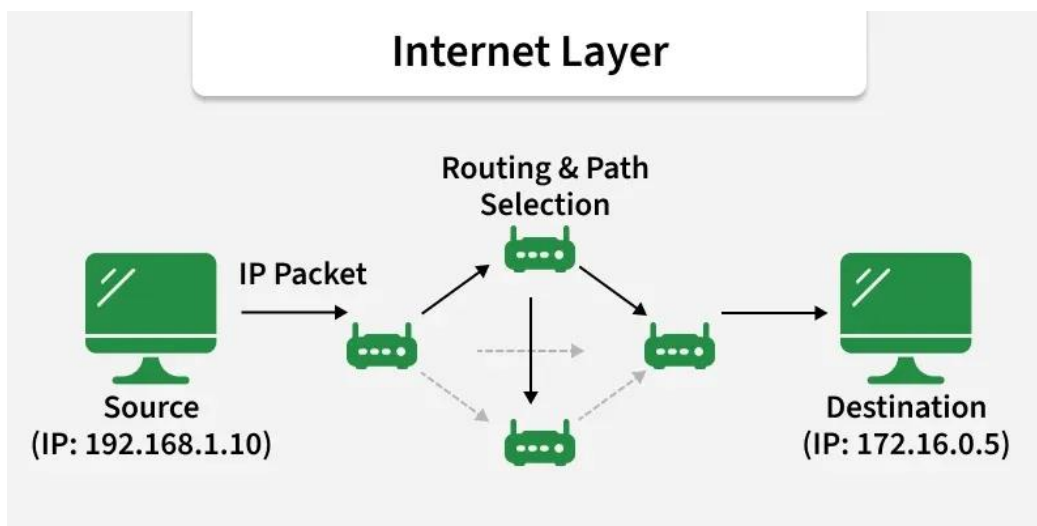
- If any data is lost or corrupted during transmission, TCP automatically resends it.
- Data is broken into packets, and TCP ensures these packets arrive in the correct sequence.
- TCP establishes a connection between sender and receiver before sending data, maintaining a stable session throughout the communication.
- Loading web pages, downloading files, sending emails, or any application where data must be complete and accurate.

UDP (User Datagram Protocol): UDP is used when speed is more important than perfect accuracy. It is faster but does not guarantee reliable delivery.

- UDP detects errors via checksums but does not verify or recover from them.
- Lost or damaged data is not resent.
- Packets may arrive out of order, and the protocol does not fix it.
- Because it avoids extra checks and connections, UDP is faster and uses fewer resources.
- Live video streaming, online gaming, VoIP calls, or real-time applications where speed matters more than reliability.

3. Internet Layer

Responsible for addressing, packaging, and routing data packets so they can travel across networks and reach the correct destination device. It ensures that data can move between different networks efficiently.



- Assigns IP addresses to identify source and destination devices.
- Determines the best path for data to travel across networks.
- Breaks large packets into smaller ones for transmission and reassembles them at the destination.
- Primarily uses IP (Internet Protocol), along with supporting protocols like ICMP for error reporting and ARP for address resolution.

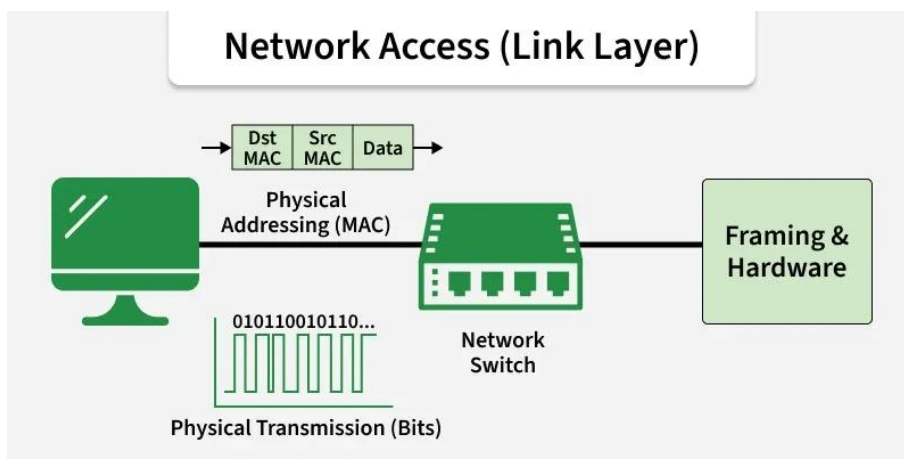
The Internet Layer is fundamental to understanding:

- IP addressing
- Routing
- Network segmentation
- Internet communication
- Firewall rules
- VPNs
- Network-based access controls

For GRC, many security controls depend on controlling communication between IP addresses and networks. A firewall rule, for example, may allow one IP network to communicate with another while blocking unauthorized networks.

4. Network Access (Link Layer)

Responsible for physically transmitting data over network hardware, including cables, switches, and wireless connections. It handles how data is formatted for the network medium and ensures it reaches the next device on the path.



Sends and receives raw bits over physical media like Ethernet cables, fiber optics, or Wi-Fi.

Organizes data into frames for proper transmission and recognition by devices.

Detects transmission errors using checksums or CRC.

Uses hardware addresses to identify devices within the same network segment.

Determines how multiple devices share the same physical medium, avoiding collisions.

For GRC, packet flow is useful when reviewing:

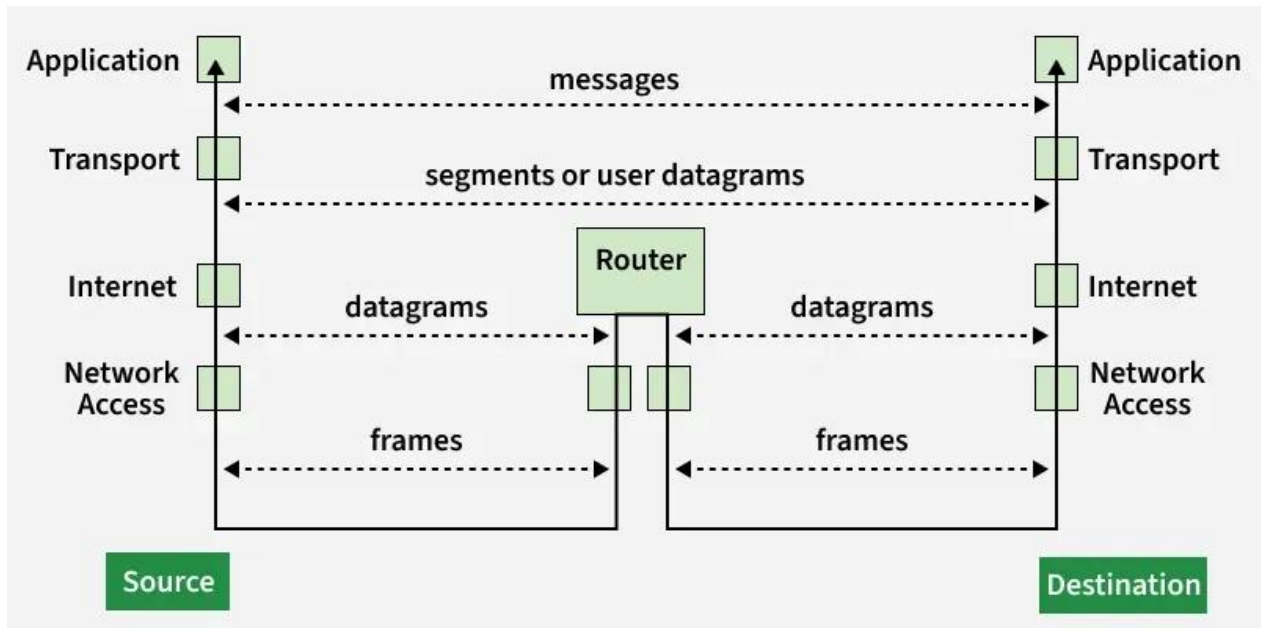
- Network architecture
- Firewall rules
- Security zones
- Data flows
- Third-party connections
- Incident investigations

- Cloud connectivity

A GRC professional should be able to understand the basic path of sensitive data and identify where security controls should exist.

Working

The working of TCP/IP can be explained with the help of the diagram given below and explained:



When Sending Data (From Sender to Receiver)

- **Application Layer:** The user's software (like a web browser or email client) creates the data and passes it to the next layer.
- **Transport Layer:** The data is broken into segments, and TCP or UDP adds control information to ensure reliable delivery or fast transmission.
- **Internet Layer:** Each segment is encapsulated into packets with IP addresses so it can be routed across networks to the destination device.
- **Network Access (Link) Layer:** The packets are converted into frames suitable for the physical network (Ethernet, Wi-Fi) and transmitted over cables or wireless signals.

When Receiving Data (At the Destination)

- **Network Access Layer:** The frames are received from the physical medium and checked for errors.
- **Internet Layer:** Frames are unpacked to extract packets and use the IP address to ensure it reaches the correct device.
- **Transport Layer:** Segments are reassembled into the original message, and any missing or corrupted data is corrected (if TCP is used).

- **Application Layer:** The complete data is delivered to the user application (like the browser displaying a webpage or the email client showing a message).

Advantages and Disadvantages of TCP/IP

Advantages

- **Widely Used:** Forms the foundation of the Internet and most modern networks.
- **Platform Independent:** Works on different hardware and operating systems.
- **Reliable Communication:** TCP ensures error checking, delivery confirmation, and data integrity.
- **Scalable:** Can support small networks to global Internet-scale networks.
- **Open Standard:** Free to use and not controlled by a single organization.

Disadvantages

- **Complexity for Beginners:** Can be difficult to fully understand all protocols.
- **No Strict Layer Enforcement:** Unlike OSI, layer boundaries are not rigid, which may cause implementation variations.
- **Overhead:** TCP's error checking and reliability features can add extra data overhead.
- **Security Limitations:** Basic TCP/IP was not designed with strong built-in security; additional protocols like TLS/SSL are needed.
- **Limited Multimedia Support:** Original design focused on data, not optimized for real-time audio/video (needs extra protocols).

Module 4 – IP Addressing

Introduction to Addresses:

- A network address serves as a unique identifier for a computer on a network.
- When set up correctly, computers can determine the addresses of other computers on the network and use these addresses to send messages to each other.
- Each device connected to a network, whether a computer, smartphone, router, printer, or server, needs a network address to function correctly.
- A network address is an identifier assigned to a networked machine that allows it to communicate with other machines. It ensures that data sent by one machine finds its destination.
- Network addresses can be physical (MAC addresses) or logical (IP addresses)
- Without network addresses, computers, smartphones, and other machines would be unable to recognize each other and exchange information on local networks (LAN) or the internet (WAN).

Physical Address (Hardware Address or Link Address).

- It is also called MAC Address(Media Access Control)
- Physical address is basically a part of data link layer.
- It is a unique hardware address assigned to every network device (computer, router, phone, etc.).
- It is permanently burned into the Network Interface Card (NIC) of a device.
- MAC addresses are mainly used in Local Area Networks (LANs) to ensure data is delivered to the

correct device. Think of a MAC address like a home address inside an apartment building. The building (network) has many apartments (devices), and each apartment has a unique number (MAC address) that helps the delivery person (router) send packages (data) to the right place.

- Since MAC addresses are unique, they are useful for network security, device tracking, and filtering.
- A MAC (Media Access Control) address is essential for identifying and managing devices within a network.
- It ensures that data packets are delivered to the correct device in a Local Area Network (LAN) by acting as a unique identifier for each network-enabled device
- They are widely used in routers, switches, and access points for managing data transmission and load balancing.
- Since each MAC address is unique, it is vital for ensuring secure and efficient device communication in both wired and wireless networks.

FORMAT:

- A MAC (Media Access Control) address consists of 12 hexadecimal characters(digits 0-9 and letters A-F) typically separated by colons, hyphens, or dots.
 - It is 48 bits long, with each pair of characters representing 8 bits
 - The First 6 digits (say 00:40:96) of the MAC Address identify the manufacturer, called the OUI (Organizational Unique Identifier). The rightmost six digits represent Network Interface Controller, which is assigned by the manufacturer.
 - The MAC address is represented by Colon-Hexadecimal notation.
 - An MAC address is a 12-digit hexadecimal number, typically formatted as six pairs of two hexadecimal digits separated by colons or hyphens (e.g., 00:1A:2B:3C:4D:5E or 00-1A-2B3C-4D-5E).
- Hexadecimal Digits: MAC addresses use 12 hexadecimal digits (0-9 and A-F).
 - Separators: These digits are usually grouped into pairs and separated by colons (:) or hyphens (-).
 - Example: A valid MAC address format is 00:1A:2B:3C:4D:5E. Colon-separated:
00:1A:2B:3C:4D:5E
 - Hyphen-separated: 00-1A-2B-3C-4D-5E
 - Dot-separated (Cisco devices): 001A.2B3C.4D5E

Logical Address (IP Address)

- It is also called an **IP Address (Internet Protocol Address)**.
- It is also called a **Virtual Address**.
- A logical address in networking is an address that **identifies a device and allows communication between devices**.
- It is a unique address that is provided by the **ISP (Internet Service Provider)** to devices in the network.
- IP addresses are used to **route data packets across networks**, ensuring that the data is delivered to the correct destination.
- A logical address is assigned to devices for **network communication**.
- It helps devices communicate across **different networks**, including the **Internet**.
- It is used to **identify and locate devices globally**.
- An IP address is like a **home address for mail delivery**, allowing data to be sent to the correct location, even if the device moves to a different network.

An **IP (Internet Protocol) address** is a unique identifier assigned to a device for communication over a network.

It comes in **two versions: IPv4 and IPv6**, each with a different format.

IPv4 Address Format

- A **32-bit (4-byte)** address written in **dotted decimal notation**.
- Consists of **four decimal numbers**, each ranging from **0 to 255**, separated by dots (.).
- **Example:** 192.168.1.1

Breakdown of IPv4 Address

192.168.1.1

- 192 → First octet (**8 bits**)
- 168 → Second octet (**8 bits**)
- 1 → Third octet (**8 bits**)
- 1 → Fourth octet (**8 bits**)

Total: 32 bits = 4 octets × 8 bits each

IPv6 Address Format

- A **128-bit (16-byte)** address written in **hexadecimal notation**.
- Consists of **eight groups of four hexadecimal digits**, separated by colons (:).
- **Full format:** 2001:0db8:0000:0000:0000:ff00:0042:8329

Total: 128 bits = 8 blocks × 16 bits each

Types of IP Address

1. **IPv4**
2. **IPv6**

Sr. No.	IPv4	IPv6
1	IPv4 has a 32-bit address length .	IPv6 has a 128-bit address length .
2	It supports Manual and DHCP address configuration .	It supports Auto and renumbering address configuration .
3	In IPv4, end-to-end connection integrity is unachievable .	In IPv6, end-to-end connection integrity is achievable .

4	The security feature is dependent on the application.	IPsec is an inbuilt security feature in the IPv6 protocol.
5	Address representation of IPv4 is in decimal.	Address representation of IPv6 is in hexadecimal.
6	Address representation of IPv4 is in decimal.	Address representation of IPv6 is in hexadecimal.
7	It has a broadcast message transmission scheme.	Multicast and anycast message transmission schemes are available in IPv6.
8	IPv4 has a header of 20–60 bytes.	IPv6 has a fixed header of 40 bytes.
9	IPv4 can be converted to IPv6.	Not all IPv6 addresses can be converted to IPv4.
10	IPv4 consists of 4 fields.	IPv4 consists of 4 fields.
11	IPv4 addresses are separated by a dot (.) .	IPv6 addresses are separated by a dot (.) .
12	IPv4 IP addresses are divided into five different classes: Class A, Class B, Class C, Class D, and Class E.	IPv6 does not have any classes of IP addresses.
13	Example: 66.94.29.13	Example: 2001:0000:3238:DFE1:0063:0000:0000:FEFB

Port Addresses

- A **port address (port number)** is a **16-bit number** that helps computers direct network traffic to the correct service or application.
- A **port number** is a way to identify a **specific process** to which an Internet or other network message is to be delivered.
- They are **16 bits in length.**
- Port numbers are **not unique for transport layer protocols.**
- The **Source Port Number** identifies the process that sends the data, while the **Destination Port Number** identifies the process that is to receive the data.
- It is always associated with an IP address and is written as **IP:Port.**
Example: 192.168.1.1:80
- Ports allow multiple applications to use the same network connection without interfering with each other.
- Port numbers are managed by the **Internet Assigned Numbers Authority (IANA)** to ensure standardization.
- They help computers differentiate between various types of communication, such as:
 - Browsing a website
 - Sending an email
 - Making a video call
- Ports enable secure communication by controlling how data is transmitted and received between devices.
- There are a total of **65,535 ports**, ranging from **0 to 65,535.**
- Ports are categorized into **three main types** based on their usage.

- **Port Numbers are also called Port Addresses.**

Types of Port Numbers

1. Well-Known Ports

- Range: **0–1023**
- Reserved for standard services such as:
 - Web browsing
 - Email
 - File transfers
- **Example:** Websites use **Port 80 (HTTP)** for normal browsing.

2. Registered Ports

- Range: **1024–49,151**
- Assigned to specific applications.
- **Examples:**
 - **Port 3306** — MySQL databases
 - **Port 25565** — Minecraft gaming servers

3. Dynamic/Private Ports

- Range: **49,152–65,535**
- Used temporarily for communication between a client and a server.
- For example, when a user accesses a website or an online service, a temporary dynamic/private port may be used for communication.

Public IP Address

- Public IP addresses are assigned by the **Internet Assigned Numbers Authority (IANA)**.
- The addresses are guaranteed to be **globally unique** and **reachable on the Internet**.
- This ensures that multiple computers do not have the same IP address.
- An **Internet Service Provider (ISP)** obtains a range of public IP addresses from IANA.
- The ISP then assigns these addresses to customers when they connect to the Internet through the ISP.
- A public IP address allows a device or network to be **identified and reached over the global Internet**.

Private IP Address

- Private IP addresses **cannot be used directly on the Internet**.
- IANA has set aside **three blocks of IP addresses** that cannot be used on the global Internet.
- These three blocks of addresses are called **Private IP Addresses**.
- They are used for networks that **do not directly connect to the Internet**.

Parts of an IP Address

An IP address consists of two main parts:

1. Network Part

2. Host Part

1. Network Part

- Represents the main network where the device is connected.
- All devices in the same network share the same network portion.
- Helps routers identify **which network the data should be sent to**.

2. Host Part

- Identifies a specific device within a network.
- A device can be a:
 - Computer
 - Phone
 - Printer
 - Other network device
- Each device within the same network has a **unique host portion**.

Classful Addresses

Classful addressing was an old method used to divide **IPv4 addresses into five classes**:

1. Class A
2. Class B
3. Class C
4. Class D
5. Class E

Each class had a **fixed division between the Network Part and the Host Part** of the address.

Class A

Network and Host Part

- The **First Byte specifies the Network Part**.
- The Network Part is **8 bits long**.
- The **Remaining Bytes specify the Host Part**.
- The Host Part is **24 bits long**.

Reserved Network Values

- Network values of **0 and 127** are reserved for Class A.

Usage

- This class is used for **large address networks**.

Example

10.0.0.1

Class B

Network and Host Part

- The **First Bytes** specify the **Network Part**.
- The Network Part is **16 bits long**.
- The **Remaining Bytes** specify the **Host Part**.
- The Host Part is **16 bits long**.

Reserved Network Values

- Network values from **128–191** are reserved for Class B.

Usage

- This class is used for **medium-sized to large-sized networks**.

Example

172.16.0.1

Class C

Network and Host Part

- The **First Bytes** specify the **Network Part**.
- The Network Part is **24 bits long**.
- The **Remaining Bytes** specify the **Host Part**.
- The Host Part is **8 bits long**.

Reserved Network Values

- Network values from **192–223** are reserved for Class C.

Usage

- This class is used for **large address networks**.

Example

192.168.1.1

Class D

- IP addresses belonging to **Class D** are reserved for **Multicasting**.
- Network values from **224–239** are reserved for Class D.

Not Used For

- **Standard device addressing**

Class E

- IP addresses belonging to **Class E** are reserved for **experimental and research purposes**.
- Network values from **240–255** are reserved for Class E.

Not Used For

- **Not assigned to normal devices**

CIDR

CIDR stands for **Classless Inter-Domain Routing**. It is a method of representing IP network ranges using a prefix length, written with a slash.

For example:

192.168.1.0/24

The /24 means that the first 24 bits identify the network, while the remaining bits are used for host addresses.

CIDR replaced the older class-based addressing approach and provides more flexible allocation of IP addresses. CIDR notation is widely used in network configurations, firewall rules, cloud security groups, routing tables, and access-control configurations.

GRC professionals regularly encounter CIDR notation in technical evidence and security configurations.

You may see CIDR ranges in:

- Firewall rules
- Cloud security groups
- VPN configurations
- Network diagrams
- Access-control lists

- Asset inventories

You do not need to perform advanced subnet calculations immediately, but you must understand what a CIDR range represents and recognize whether a rule is narrowly or broadly scoped.

NAT

NAT stands for **Network Address Translation**. It is a process in which a network device, usually a router or firewall, modifies IP address information as traffic moves between networks.

The most common use of NAT is allowing multiple devices using private IP addresses to access the Internet through one or more public IP addresses.

NAT helps conserve public IPv4 addresses and hides internal addressing from direct exposure. However, NAT is **not a complete security control**. It should not be confused with a firewall or treated as a substitute for properly configured access controls.

GRC professionals may encounter NAT when reviewing:

- Network architecture
- Internet exposure
- Firewall configurations
- Cloud networking
- Remote access
- Data flow diagrams

A common mistake is assuming that because an internal address is hidden through NAT, it is automatically protected. Actual security depends on firewall rules, authentication, segmentation, monitoring, and other controls.

NAT modifies addressing.

A firewall enforces traffic-control rules.

They may exist on the same device but perform different functions.

Common NAT Types

Static NAT

→ One private IP is mapped to one public IP.

Dynamic NAT

→ Private IP addresses are mapped dynamically from a pool of public IP addresses.

PAT (Port Address Translation)

→ Multiple private devices share a public IP address using different port mappings.

PAT is often called **NAT Overload**.

DHCP

DHCP stands for **Dynamic Host Configuration Protocol**. It automatically provides devices with network configuration information such as an IP address, subnet mask, default gateway, and DNS server.

Without DHCP, administrators may need to manually configure network settings on every device. DHCP makes network administration more efficient and reduces configuration errors.

The basic DHCP process is commonly remembered as **DORA**:

Discover → Offer → Request → Acknowledge

The device requests configuration, the DHCP server offers information, the device requests the offered configuration, and the server acknowledges the assignment.

DHCP is an important enterprise network service. If it fails, new devices may be unable to obtain network configurations and therefore may not be able to communicate properly.

From a GRC perspective, DHCP is relevant to:

- Network availability
- Asset identification
- Network administration
- Unauthorized device detection
- Logging and monitoring

DHCP Can Provide

- IP address
- Subnet mask
- Default gateway
- DNS server
- Lease duration

Important Concepts

DHCP Lease

The IP address is assigned for a defined period.

DHCP Reservation

A specific device can consistently receive the same assigned IP address.

DHCP Scope

The range of IP addresses and configuration options managed by a DHCP server.

Security Considerations

- Protect DHCP infrastructure.
- Monitor unauthorized DHCP servers.
- Maintain appropriate logging.
- Restrict administrative access.
- Consider redundancy for critical environments.

DNS

DNS stands for **Domain Name System**. DNS translates human-readable domain names, such as company.com, into IP addresses that network systems use for communication.

Without DNS, users would need to remember the IP addresses of websites and systems. DNS acts like a distributed naming system for networks and the Internet.

When a user enters a domain name, the device queries DNS to determine the corresponding IP address. The device can then establish communication with the destination.

2. Why It Matters

DNS is critical infrastructure. If DNS is unavailable, users may be unable to access websites, cloud applications, email services, and internal systems even when the underlying network is functioning correctly.

DNS is also heavily targeted by attackers and can be abused for:

- Phishing
- Malware communication
- Command and control
- DNS spoofing
- Data exfiltration

For GRC, DNS is relevant to security architecture, logging, monitoring, availability, and incident investigation.

Basic Process

User enters domain name

→ DNS query

→ DNS returns IP address

→ Device connects to the destination

Common DNS Records

A Record

Maps a domain name to an IPv4 address.

AAAA Record

Maps a domain name to an IPv6 address.

MX Record

Identifies mail servers.

CNAME Record

Creates an alias for another domain name.

TXT Record

Stores text-based information and is commonly used for domain verification and email security configurations.

Security Considerations

- Protect DNS configuration.
- Restrict unauthorized changes.
- Monitor DNS activity.
- Use secure DNS architecture where appropriate.
- Protect critical DNS infrastructure.
- Maintain redundancy.

ARP

ARP stands for **Address Resolution Protocol**. It is used within an IPv4 local network to find the **MAC address associated with a known IP address**. A device may know the IP address of another device it wants to communicate with, but to deliver data across the local network, it also needs the destination MAC address.

The basic process works like this: the sending device checks its **ARP cache** first. If the required IP-to-MAC mapping is not available, it sends an **ARP request** as a broadcast across the local network asking, essentially, “Who has this IP address?” The device with that IP address responds with an **ARP reply** containing its MAC address. The sender stores this mapping temporarily and can then send the frame to the correct destination.

An important distinction is that **ARP operates within the local network**. If the destination is on another network, the device does not need the remote system's MAC address. Instead, it uses ARP to find the MAC address of its **default gateway**, usually a router, and sends the frame there for further routing.

ARP is important for understanding how IP-based communication actually works inside a local network. From a GRC and cybersecurity perspective, ARP is relevant because attackers can exploit weaknesses in the protocol through techniques such as **ARP spoofing or ARP poisoning**.

In an ARP spoofing attack, an attacker may send false ARP information to associate their MAC address with the IP address of another system, such as a gateway. This can potentially allow the attacker to intercept or manipulate local network traffic.

When reviewing network security, you should understand that ARP-related risks may be addressed through controls such as:

- Network segmentation
- Switch security features
- Dynamic ARP Inspection (DAI)
- Network monitoring
- Detection of unusual ARP activity
- Secure network architecture
- **ARP's Main Purpose**
Maps an IPv4 address to a MAC address within a local network.
- **ARP Cache**
A device stores recently learned IP-to-MAC address mappings temporarily in an ARP table or cache.
- **ARP Request**
The sending device broadcasts a request asking which device owns a specific IP address.
- **ARP Reply**
The device with the requested IP address responds with its MAC address.
- **Local Network Communication**
For devices on the same network, ARP helps identify the destination device's MAC address.
- **Communication with Another Network**
The source device usually uses ARP to discover the MAC address of the default gateway rather than the MAC address of the remote destination.
- **ARP Security Risk**
ARP does not inherently provide strong authentication, which makes spoofing or poisoning attacks possible.
- **Important GRC Point**
ARP is a technical networking mechanism, but ARP-related attacks demonstrate why network security requires more than IP addressing. Monitoring, segmentation, secure switch configuration, and technical controls are necessary to protect internal communications.

Module 6 – Network Security

Secure Protocols

Secure protocols are communication protocols designed to protect data while it travels between systems. Their main purpose is to prevent unauthorized parties from reading, modifying, or impersonating communications. They typically use encryption, authentication, and integrity protection.

The important principle is that a protocol can perform the correct business function but still be insecure. For example, HTTP and HTTPS both support web communication, but HTTPS protects the communication using TLS. Similarly, Telnet and SSH both allow remote access, but SSH provides encrypted and authenticated communication.

Unencrypted or legacy protocols can expose sensitive information such as usernames, passwords, business data, and administrative commands. A GRC professional must

understand whether an organization has standards defining approved protocols and whether insecure alternatives are disabled.

This is relevant during configuration reviews, vulnerability assessments, audits, and compliance assessments.

Wireless Security

Wireless security protects Wi-Fi and other wireless communications from unauthorized access, interception, and misuse. Unlike a wired connection, wireless signals travel through the air, which means attackers may attempt to access or intercept the network without physically connecting to a cable.

Wireless security therefore requires strong authentication, encryption, proper access-point configuration, network segmentation, and continuous monitoring.

Important controls

- Use modern Wi-Fi security such as WPA3 where supported
- Use strong authentication
- Avoid outdated protocols such as WEP
- Separate guest Wi-Fi from corporate networks
- Change default administrative credentials
- Secure access-point management interfaces
- Monitor for rogue or unauthorized access points
- Apply firmware and security updates

Enterprise environments

Organizations may use centralized authentication, such as **802.1X**, instead of relying only on a shared Wi-Fi password.

NAC

NAC stands for **Network Access Control**. It is a security approach used to control which users and devices are allowed to connect to a network and what level of access they receive.

NAC can evaluate a device before or when it connects to the network. Depending on organizational policy, it may check the user's identity, device identity, security posture, compliance status, or other conditions.

A device that does not meet required security conditions may be denied access, given limited access, or placed into a quarantine network.

Traditional network access often assumed that any device physically connected to the corporate network could be trusted. NAC reduces this assumption by verifying devices and enforcing access requirements.

For GRC, NAC demonstrates how a policy requirement can be translated into a technical control. For example, an organization may require devices accessing sensitive systems to have approved security software and current patches.

Secure Remote Access

Secure remote access allows authorized users, administrators, vendors, or employees to access organizational systems from outside the normal corporate network while protecting the connection and enforcing access controls.

Remote access became a major part of enterprise security because users may work from homes, hotels, client sites, or other external locations. The organization must therefore extend security controls beyond its physical office network.

Secure remote access generally combines authentication, encryption, authorization, device security, and monitoring.

Remote access creates additional risk because external networks may be untrusted or compromised. Weak remote access can lead directly to unauthorized access to internal systems.

For GRC, this area is relevant to:

- Access control policies
- Remote work policies
- Third-party access
- Privileged access
- MFA requirements
- Logging and monitoring
- Vendor risk management

Important controls

- Strong authentication
- Multi-factor authentication
- Encryption of communications
- Least-privilege access
- Restricted administrative access
- Approved and managed devices where appropriate
- Session logging and monitoring
- Regular review of remote access permissions

Common technologies

- VPN
- Secure remote administration
- Zero Trust Network Access (ZTNA)
- Privileged access solutions

Remote access should provide access only to the resources required. Giving every remote user broad access to the entire internal network creates unnecessary risk.

Logging

Network logging is the process of **recording network-related events and activities** so they can be reviewed, investigated, and analyzed. Network devices such as firewalls, routers, switches, VPN gateways, IDS/IPS systems, proxies, and DNS servers can generate logs.

A network log can contain information such as source and destination IP addresses, ports, connection attempts, allowed or blocked traffic, authentication events, configuration changes, and security alerts.

Logs provide a historical record of what happened. Without appropriate logging, an organization may have little evidence to determine whether an event occurred, when it occurred, which systems were involved, and what actions were taken.

Logging is critical for **incident response, security monitoring, audits, investigations, and compliance**.

For a GRC professional, the important question is not simply whether logging exists. You need to determine whether:

- Appropriate events are being logged.
- Logs are protected from unauthorized modification.
- Logs are retained for the required period.
- Time synchronization is maintained.
- Logs are reviewed or monitored.
- Critical security events generate alerts.
- Log access is restricted.

Important network events may include:

- Firewall allow/deny events
- VPN connections
- Authentication failures
- Administrative activity
- Configuration changes
- Network anomalies
- IDS/IPS alerts
- DNS activity
- Connection attempts

- Security policy violations

Centralized logging is preferred in enterprise environments because collecting logs from multiple devices into a centralized platform makes correlation and investigation easier.

Logs may be sent to a **SIEM**, where events from different systems can be correlated.